UNIVERSITY OF LONDON

BSc EXAMINATION 2024

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3612: CRITICAL INFRASTRUCTURE SECURITY

IY3612R: CYBER SECURITY – PAPER FOR FIRST SITS/RESIT CANDIDATES

Time Allowed: **TWO** hours

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Attempt **three** questions.

No credit will be given for attempting any further questions.

© Royal Holloway University of London 2024

Question 1 Control Systems Security

(a) An adversary has successfully intercepted a shipment of intelligent electronic devices (IEDs) for operating valves before these were delivered to a gas network operator using this to control operation of compressors in a supply chain attack.

The adversary has changed the firmware of the IEDs so that their behaviour would be altered if a certain set of conditions is met, therefore without requiring any outside connection or intervention. The manipulation has been undertaken so that the modified IEDs would not communicate with the outside differently to un-modified devices.

(i) Which harmful effects can such **un-coordinated** activity have on a cyber-physical system such as a gas pipeline or compressor? Give a brief, reasoned answer. [6]

(ii) Can the operator of the network determine whether the equipment such as actuators is not exhibiting any unusual behaviour, and if so, how? Identify an approach and any limitations this may have. [7]

(b) In a separate attack schema, an adversary is able to perform a supply chain attack by modifying a component that will be connected to one of the target's field bus systems.

As in question 1(a), no external connection or communication is possible, and the adversary does not have deeper insight into the actual workings of the targeted cyber-physical system other than knowing that this system will be using the IEC 61850 GOOSE/SV protocol.

(i) Describe an attack which a *single* manipulated device located on a field bus may launch under these circumstances; give a reasoned outline of the effects and limitations of the attack. [6]

(ii) If security measures according to IEC 64283 are in use, can the attack described in question 1(b)(i) still succeed? Give a brief, reasoned answer. [6]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2 Threat and Adversary Modelling

(a) The MITRE ATT&CK framework is primarily used to *describe* the steps taken by adversaries to achieve a desired set of objectives, but can also be used for developing adversary profiles or analysing trends in attack patterns and activities.

Two tactics in the MITRE ATT&CK matrix are **Discovery** and **Lateral Movement** describing how adversaries will conduct reconnaissance after gaining an initial foothold, and then move further from an existing compromise.

(i) If the defender is assuming an initial compromise, how can this matrix enable the prediction of steps, or at least techniques, for subsequent adversary actions? Give a brief, reasoned answer. [6]

(ii) Could the MITRE ATT&CK framework be used for *automating* red team exercises in industrial control systems? Give a reasoned answer. [6]

(b) Whilst a number of models exist that allow the study of attack surfaces and attacks such as Microsoft's STRIDE threat modelling framework, such more abstract perspectives are not always sufficient.

(i) Which benefits can an attack (or attack defence, attack countermeasure, etc.) type modelling approach for threats have over an adversary and threat model in which threats are already grouped and categorised? Give a brief, reasoned answer. [6]

(ii) In an Attack Tree, different possible approaches for an adversary to achieve their objective can be described, also allowing an adversary to determine an efficient path to a given goal (see figure 1)

If a new method for achieving a higher-level objective is discovered by either attacker or defender, how will this impact the construction of the Attack-Defence Tree? Give a brief, if necessary qualitative answer. [7]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

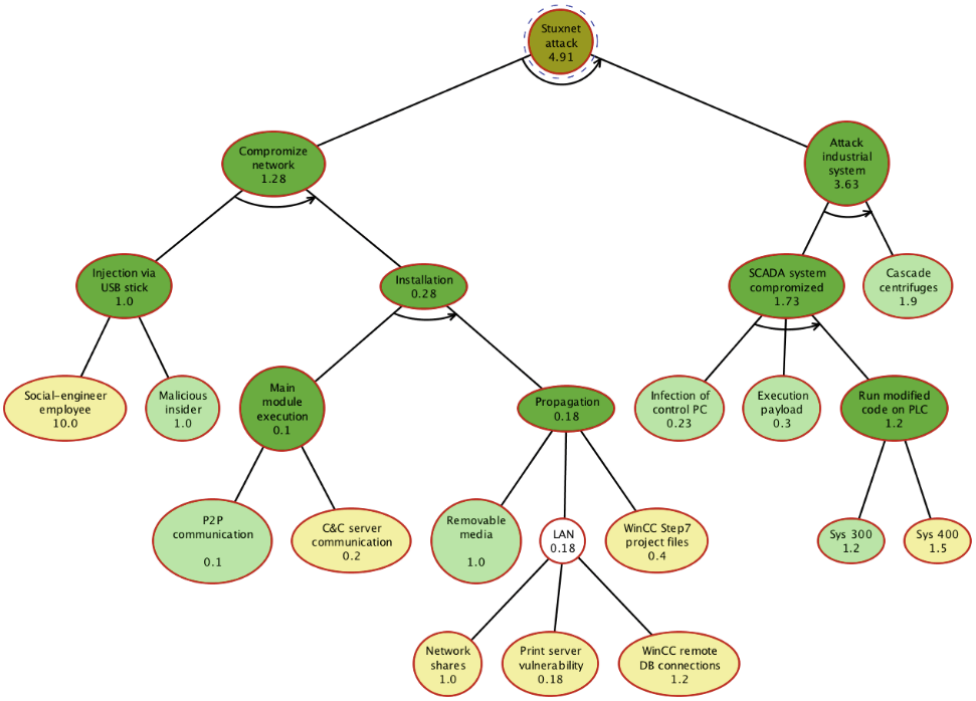

Figure 1: Attack Tree for Stuxnet attack (Source: Gadytskaya *et al.*, 2016)

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3 Cyber Conflict

(a) The dictator of Evilstan has decided to launch an attack against neighbouring Nicestonia, but which is below the threshold of warfare since he does not wish to upset Nicestonia's neighbours.

(i) The head of the Evilstanian cyber forces suggests an attack against the Nicestonian National Bank's payment processing system, which would be masqueraded as a criminal ransomware attack for the purposes of deniability.

Would this arms-length relation to the actual attacker be sufficient to insulate Evilstan from possible retaliation? Give a brief, reasoned answer. [6]

(ii) Not to be outdone, the head of the Evilstan Navy proposes an attack against the sub-sea data cables linking Nicestonia to its friendlier neighbours, masqueraded as a foreign-flagged fishing vessel accidentally deploying its dredging nets right on top of the cabling. This would render much of Nicestonia's cloud infrastructures throughout, also its critical national infrastructures such as the health service, inoperable.

Would Nicestonia be able to replace the capacity of the sub-sea cables until these can be repaired if all of its land borders are to Evilstan or its allies? Give a brief, reasoned answer. [7]

(b) The country of Reasonablynicia has recently been the subject of multiple waves of cyber attacks against its critical national infrastructure as well as targeted ransomware attacks against industry and critical sectors.

It has hence decided to launch a "*hack back*" attack to take out the infrastructure of the ransomware groups that appear to be the origin of the attacks, which seem to point to systems located in Evilstan.

Identify risks arising from such an attack on non-state, but possibly state-sanctioned, groups in a foreign country, discussing also the affected network infrastructure. Give a reasoned, brief answer. [12]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4 Network Infrastructure Security

(a) The *Border Gateway Protocol* (BGP) underpins the global interconnection of the Internet by linking together networks of networks (grouped into *Autonomous Systems* (AS).

(i) Describe the way in which a rogue or mis-configured AS may "hijack" the prefix of a legitimate entity and perform a man-in-the-middle attack. You may wish to use diagrams for this purpose. [6]

(ii) How can the legitimate owner of a prefix learn or suspect if such a man-in-the-middle attack may be occurring? Give arguments for which indicators may be used, and how reliable these may be. [6]

(b) Whilst BGP was defined without integrated security features, this issue has long been recognised and addressed by the Internet Engineering Task Force (IETF) in the form of BGP Security (BGPsec).

Identify which mechanisms of BGPsec must be operational and where in order for the prefix hijacking described in question 4(a) to be prevented or mitigated. You may wish to use diagrams to answer this question. [13]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 5 Dependency Models

(a) Many critical infrastructure networks exhibit emergent properties and can be described by a power-law distribution at sufficiently large scale. This insight is also available to potential adversaries.

(i) If an adversary is able to learn the number of neighbours (the degree) of a small number of nodes in the targeted network relative to the total number, which insights (if any) may the adversary gain from such information that can help in tailoring an attack? Give a brief, reasoned answer. [7]

(ii) The defender of the network in question 5(a)(i) will know the degree distribution and also the degree of each node. How can the defenders utilise this knowledge asymmetry if they are able to introduce small changes to the network topology by adding or removing a small number of edges to/from the network? Give a brief, reasoned answer. [6]

(b) Social interaction graphs are an important tool for adversaries to construct attack campaigns that require steps such as spear-phishing to gain access.

(i) Assume that an adversary were to target a particular department or unit inside an organisation but did not have the names or further information on individuals in this unit.

If the adversary were to obtain an incomplete relation graph containing several individuals working in the same organisation as the targets, would this be useful for the adversary? Give a brief, reasoned answer. [6]

(ii) Social interaction graphs may also be used by defenders in the prevention of ransomware attacks spreading within an organisation.

Which properties of the graph may be useful for this end? Give a brief, reasoned answer. [6]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

END

Stephen Wolthusen

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.